RiskPilot AI Agentic Cyber Defence Report

Wong Li En, Tian Xinyu, and Wong Chin Wen

Taylor's University

HackAI 2026

Cyber Defence Track

October 24, 2026

> RiskPilot AI organises historical network alerts into evidence-linked cases and uses a bounded AI agent to investigate them. It produces an explainable assessment and a proposed investigation plan for an analyst to review. The demonstrated scope covers PortScan, DoS and suspected BruteForce activity.

1 Problem and user

1.1 The triage problem

A network alert identifies behaviour that matches a detection rule. An analyst still needs to establish what happened, which evidence supports the signal and what to investigate next. Reviewing isolated alerts makes it difficult to follow activity over time or distinguish an observed traffic pattern from an inferred attack.

The same source may generate alerts across multiple minutes. Treating every alert as a separate investigation fragments the evidence, while treating a rule match as proof of compromise can produce an unsupported conclusion. Effective triage needs both correlation and a clear way to express uncertainty.

1.2 Intended users

The prototype supports Tier 1 and Tier 2 security operations centre analysts. A first reviewer can understand the trigger, inspect the timeline and use the AI findings to identify the next useful check. A more experienced analyst can review the cited records, accept or reject the assessment and decide whether further investigation is justified.

1.3 Project objective

We built a case-centred investigation workflow that connects rule alerts, traffic evidence, AI reasoning and analyst decisions. Its defensive output is a prioritised review queue and an evidence-linked investigation plan. The prototype replays historical flow data; operational response remains under human control.

2 Inputs and evidence

2.1 Data and scope

Development uses labelled network-flow data from CIC-IDS2017 (Canadian Institute for Cybersecurity, n.d.; Sharafaldin et al., 2018). The selected files cover Monday, Tuesday, Wednesday and Friday afternoon PortScan traffic. The application displays three detection categories: PortScan, DoS and BruteForce. Benign is used only as an offline evaluation label; it is not a detection rule or an automatic safe verdict.

The demonstration contains 9 grouped cases, 158 alerts and 948 sampled flow records. Its 1,106 timeline events link to an alert or retained sample. Each sample retains its source-file and row reference so the analyst can trace it to the underlying data.

2.2 Detection basis

Rules operate on a source file, ordered source and destination IP pair, and calendar minute. One CSV row counts as one flow record; forward and backward packet counts are summed. The following thresholds are prototype heuristics.

Category	Rule signal within one minute
PortScan	At least 100 flows and 100 destination ports, plus either source ports at least twice destination ports, or at least 250 destination ports and 2 source ports.
DoS	At least 1,000 flows and 10,000 packets, at most 10 destination ports and at least 10 source ports.
BruteForce	At least 50 connections from one source to one target FTP port 21 or SSH port 22.

A rule signal warrants investigation. Repeated connections to a login port do not establish failed passwords, and traffic volume does not establish service disruption. An unmatched record is not automatically classified as Benign.

2.3 Case grouping and evidence access

Alerts are grouped when their source file, rule type, ordered address pair and time proximity match, with at most five minutes between alert-minute starts. BruteForce grouping also requires the same target login port. Separate sources or destinations remain separate cases, although related cases can be linked.

The interface provides minute-level drill-down, sampled evidence and paginated access to locally indexed original flow records. AI tools receive case-scoped aggregates and bounded samples. Dataset labels and analyst-only annotations are withheld from the model. Source timestamps are shown as dataset time rather than assuming an unverified timezone.

3 Agent workflow

3.1 Investigation process

The analyst opens a case and starts an AI investigation, or enables sequential investigation of pending cases. The AI first reads the case details, then selects evidence queries according to what it needs to verify. The backend executes only allowlisted read-only tools and returns the results to the model. The agent can request further evidence before producing its proposal.

Read-only tool	Purpose
Case details	Read the addresses, complete grouped time range, flow total and evidence scope.
Related alerts	Inspect the rule measurements and linked alert IDs, with continuation for longer lists.
Network flows	Inspect sampled communication records, including ports, packet counts and evidence IDs.
Incident statistics	Read case aggregates and statistics explicitly derived from the retained samples.

The investigation is limited to six model steps and twelve tool calls. Tools are scoped to the active case. Unknown tools, invalid arguments and requests for another case are refused. Bounded tool responses preserve valid structured data and identify omitted records. Provider failures produce an unavailable state rather than a substituted mock conclusion.

3.2 Assessment and evidence checks

The agent proposes Likely Attack, Likely Benign or Needs Review, together with its reasoning, model-reported confidence, cited records, findings, limitations and up to two next steps. Observation and inference are presented separately. Confidence is not a calibrated probability of attack.

The backend checks the case identity, allowed output fields, evidence ownership, retrieved citations, supported numeric claims and specified time-window conflict claims. New results carry an evidence fingerprint so changed case evidence invalidates the cached proposal. Rejected proposals are withheld from confirmation and recommendation approval. These checks constrain output; they do not prove every interpretation correct.

3.3 Timeline and ATT&CK context

The timeline orders the case evidence and opens the relevant record from a finding or recommendation. PortScan evidence may support a tentative T1046 Network Service Discovery mapping (MITRE, 2026b). DoS and BruteForce remain Unmapped when the flow data cannot establish service impact or credential guessing, as described by T1498 (MITRE, 2025) and T1110 (MITRE, 2026a). Mapping hints remain distinguishable from confirmed attacks.

4 Defensive action

RiskPilot AI helps an analyst decide where to focus and what evidence to examine next. The case view combines the rule signal, timeline, AI findings and proposed investigation steps. Each suggested step includes its rationale and links to supporting evidence.

The queue uses an explainable review-priority heuristic based on traffic rate, related alert count, source diversity and destination-port spread. High, Medium and Low indicate review order. They are not calibrated severity levels or probabilities. Analysts can inspect the contributing reasons and record a justified manual adjustment in the audit trail.

Permitted proposals are to review network flows, check related alerts, review the incident timeline or escalate to an analyst. The agent has no tool for blocking an address, isolating a host, modifying evidence or closing a case. Its authority is restricted to investigation and proposed next steps, consistent with limiting excessive agency (OWASP Foundation, n.d.).

5 Human approval

The system separates the AI proposal from the analyst decision. Viewing evidence is read-only; confirming a conclusion, approving a step and resolving a case are distinct operations.

Analyst decision	Meaning and recorded effect
Confirm or reject assessment	Records the analyst judgment about the AI interpretation. Rejection requires a reason; confirming Likely Benign on a protected attack category also requires a written reason.
Approve or reject a step	Records selected investigation-plan decisions. Approved steps enter the pending work list and create a case-note draft. Approval does not execute the investigation.
Save case record	Preserves the investigation summary as an audit snapshot. Optional unreviewed steps remain visible as such. Saving does not resolve the case.
Resolve case	Requires a saved record, an explicit analyst confirmation and a written reason. Resolution removes the case from the active review queue.

Approved work is completed by the analyst and marked done separately. The case-note draft remains a draft. The printable case record includes case facts, detection evidence, the AI assessment, analyst review, investigation-plan decisions and activity history.

Write operations use an authenticated session and CSRF protection, and the reviewer must match the signed-in user. AI activity, validation outcomes, analyst decisions, drafts and saved records enter a shared audit trail. A hash chain and database update/delete restrictions support append-only auditing through normal application access.

6 Result and limitations

6.1 Working prototype

The application demonstrates grouped case investigation across 9 cases, with all 1,106 exported timeline events resolving to case evidence. The software suite passed 280 automated tests, including evidence validation, case boundaries, reviewer identity, safe resolution and audit behaviour. A separate set of 21 synthetic safety scenarios passed. These are functional checks rather than measures of detection accuracy or analyst effectiveness.

6.2 Detection results

Development scoring evaluated 356,103 minute groups, excluding 11 out-of-scope groups. Across the target attack types, the detector recorded 156 true positives, 2 false positives and 73 false negatives:

binary precision 98.73% and recall 68.12%. The Benign false-positive rate was 2 of 355,863 groups, approximately 0.000562%. These data informed development and are not an independent test.

Category	Development precision	Development recall	External recall
PortScan	91.67%	40.74%	0.118%
DoS	95.83%	30.67%	41.176%
BruteForce	100.00%	96.06%	0.359%

The independent-source detector evaluation used CIDDS-001 OpenStack internal weeks 1 to 4 (Hochschule Coburg, n.d.). It scored 5,942,316 minute groups after excluding 4,260 ambiguous or out-of-scope groups. The thresholds were fixed before scoring. The low external recall shows that the current rules do not generalise reliably, especially for PortScan and BruteForce. Zero observed external false positives must be read alongside the small number of positive predictions.

6.3 Real AI investigation example

The investigation examined case INC-A787E11F2A22, which contained 61 BruteForce-rule alerts between 09:19 and 10:19 on 4 July 2017. It completed in 54.89 seconds using four read-only tool calls and four cited records. The agent returned Needs Review with medium confidence: repeated connections warranted investigation, but the evidence could establish neither credential guessing nor a legitimate purpose.

The agent proposed reviewing the linked flow patterns and escalating for authentication-log and authorised-activity checks. Its output passed evidence validation. An isolated workflow test recorded a simulated analyst confirmation, one approved step, a DRAFT case note and a saved case record. The resulting ten-event audit chain verified successfully. This single case demonstrates the workflow; it does not establish AI classification accuracy or human decision quality.

6.4 Limitations

Detection coverage is the main limitation. Attacks missed by the initial rules do not reach the normal AI investigation queue. Fixed minute boundaries can split activity, simple count thresholds can miss slow behaviour, and first-match rule priority can mask overlapping signals. Address-and-time grouping is a practical correlation method, not proof of a common campaign.

Flow samples lack authentication outcomes, payload content, asset importance, business context and service-health evidence. These gaps limit conclusions about BruteForce, DoS impact and intent. ATT&CK hints remain tentative, and incomplete evidence should result in further review rather than a forced attack or benign decision.

AI confidence is model-reported and uncalibrated. Deterministic checks verify selected evidence and claim constraints, not all reasoning or causal assertions. The demonstrated Codex configuration uses a default model alias rather than a pinned underlying version. Broader evaluation needs separate external cases, expert review and measurement of both errors and abstention.

The prototype has not measured investigation-time savings, workload reduction or improved analyst outcomes. Approval clicks and written reasons establish accountability, not the correctness of the security judgment. The locally verifiable audit chain is also not tamper-proof against an administrator able to replace the application and storage.

Future work should strengthen evidence coverage, evaluate detection on disjoint calibration and test data, and measure usability with analysts. The current contribution is a working, constrained investigation workflow with traceable evidence and explicit human decisions.

References

Canadian Institute for Cybersecurity. (n.d.). *Intrusion detection evaluation dataset (CIC-IDS2017)*. University of New Brunswick. https://www.unb.ca/cic/datasets/ids-2017.html

Hochschule Coburg. (n.d.). *CIDDS: Coburg intrusion detection data sets*. https://www.hs-coburg.de/forschen/cidds-coburg-intrusion-detection-data-sets/

MITRE. (2025, October 24). *Network denial of service (T1498)*. MITRE ATT&CK. https://attack.mitre.org/techniques/T1498/

MITRE. (2026a, May 12). *Brute force (T1110)*. MITRE ATT&CK. https://attack.mitre.org/techniques/T1110/

MITRE. (2026b, May 12). *Network service discovery (T1046)*. MITRE ATT&CK. https://attack.mitre.org/techniques/T1046/

OWASP Foundation. (n.d.). *LLM06:2025 excessive agency*. OWASP Gen AI Security Project. https://genai.owasp.org/llmrisk/llm062025-excessive-agency/

Sharafaldin, I., Lashkari, A. H., & Ghorbani, A. A. (2018). Toward generating a new intrusion detection dataset and intrusion traffic characterization. In P. Mori, S. Furnell, & O. Camp (Eds.), *Proceedings of the 4th International Conference on Information Systems Security and Privacy* (Vol. 1, pp. 108–116). SciTePress. https://doi.org/10.5220/0006639801080116